

CVEs más relevantes de la semana

Del 07/07/2026 al 14/07/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-13020

Descripción: A Weak Password Recovery Mechanism for Forgotten Password exists in Esri Portal for ArcGIS versions 12.1 and earlier on Windows, Linux and Kubernetes. A remote, unauthorized attacker may assume ownership of a user's account by manipulating this mechanism. ArcGIS Administrators should configure an email server with ArcGIS Enterprise to facilitate user self-service password recovery. The ability ...

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-640

Tecnología: No especificado

Publicado el: 2026-07-07



CVE-2026-60002

Descripción: ssh in OpenSSH before 10.4 can have a use-after-free when a server changes its host key during a key re-exchange. (This outcome occurs only on the client side.)

CVSS: 7.7 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:L

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-07-08



CVE-2026-58480

Descripción: Blocksy Companion Pro plugin for WordPress before 2.1.47 contains an unauthenticated arbitrary file upload vulnerability that allows attackers to upload executable files by bypassing extension validation in the `save_attachments` function exposed through the Advanced Reviews feature. Attackers can exploit the Custom Fonts extension's flawed `strpos()` substring check by uploading double-extension f...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-07-08



CVE-2026-3144

Descripción: IBM API Connect 12.1.0.0 through 12.1.0.3 uses default credentials which could allow an attacker to gain unauthorized access to the application before the system enforces a credential update.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-1392

Tecnología: No especificado

Publicado el: 2026-07-08



CVE-2026-9074

Descripción: IBM API Connect 10.0.8.0 through 10.0.8.9 and 12.1.0.0 through 12.1.0.3 contains an unauthenticated SQL injection vulnerability in the password reset functionality.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-07-08



CVE-2026-8649

Descripción: Improper Neutralization of Special Elements in Data Query Logic vulnerability in Progress MOVEit Transfer (Custom Reports modules).

This issue affects MOVEit Transfer: before 2025.0.7, from 2025.1.0 before 2025.1.3.

CVSS: 6.4 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:H/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-943

Tecnología: No especificado

Publicado el: 2026-07-08



CVE-2026-8801

Descripción: Path equivalence: vulnerability in Progress MOVEit Transfer (File Upload modules).

This issue affects MOVEit Transfer: before 2025.0.8, from 2025.1.0 before 2025.1.4.

CVSS: 3.5 (LOW)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:N/I:L/A:N

Tipo: CWE-46

Tecnología: No especificado

Publicado el: 2026-07-08



CVE-2026-47826

Descripción: The blobs.yml path key traversal vulnerability in the BOSH CLI tool allows an attacker to write arbitrary files and exfiltrate sensitive information. Affected versions: BOSH CLI tool versions prior to v7.10.4.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-07-09



CVE-2026-56291

Descripción: The Joomla extension Balbooa Forms is vulnerable to an unauthenticated arbitrary file upload that allows uploading executable files and leads to full RCE.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-07-09



CVE-2026-58459

Descripción: gpsd through release-3.27.5, fixed at commit 4c06658, contains a command injection vulnerability in gpsprof that allows attackers who control the GPS device subtype value to execute arbitrary shell commands by embedding backtick payloads in the gnuplot plot title without proper escaping. The subtype field sourced from a DEVICES JSON log entry or NMEA PGRMT sentence is written into a generated g...

CVSS: 7.8 (HIGH)

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-07-09



CVE-2026-59214

Descripción: Open WebUI is an extensible, feature-rich, and user-friendly self-hosted AI platform. Prior to 0.10.0, Open WebUI runs client-side Python with Pyodide in a same-origin web worker, allowing stored chat payloads that use `pyodide.http.pyfetch` or the `js` module `fetch` and `XMLHttpRequest` APIs to issue authenticated same-origin requests when a victim clicks Run, which can reach admin-only endpoints and...

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:N

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-07-09



CVE-2026-59216

Descripción: Open WebUI is an extensible, feature-rich, and user-friendly self-hosted AI platform. Prior to 0.10.0, get_event_call delivered execute:python and execute:tool Socket.IO events to a client-supplied session_id after checking only that the session was connected, allowing authenticated users who learned another socket ID through ydoc:document:join to run code interpreter Python or tools in that us...

CVSS: 7.7 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:C/C:H/I:H/A:N

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-07-09



CVE-2026-0284

Descripción: An XML injection vulnerability in the Large Scale VPN (LSVPN) functionality of Palo Alto Networks PAN-OS[] software enables an unauthenticated attacker with network access to inject malicious XML content, potentially leading to information disclosure or corruption of internal LSVPN satellite data.

Panorama, Cloud NGFW, and Prisma[] Access are not impacted by this vulnerability.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-07-09



CVE-2026-53963

Descripción: Discourse is an open-source discussion platform. Prior to 2026.6.0, 2026.5.1, 2026.4.2, and 2026.1.5, a malicious second factor name on an attacker-controlled account was not escaped in the delete confirmation dialog, allowing stored cross-site scripting when an administrator impersonated that account. This issue is fixed in versions 2026.6.0, 2026.5.1, 2026.4.2, and 2026.1.5.

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:N

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-07-09



CVE-2026-59792

Descripción: In JetBrains IntelliJ IDEA before 2026.1.4, 2026.2 code execution via path traversal in project workspace ID handling was possible

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:L

Tipo: CWE-23

Tecnología: No especificado

Publicado el: 2026-07-10



CVE-2026-57156

Descripción: FreeRDP is a free implementation of the Remote Desktop Protocol. Prior to 3.28.0 on 32-bit builds, FreeRDP clients contain an integer overflow in `update_read_delta_points` in `libfreerdp/core/orders.c` when multiplying an attacker-controlled point count by `sizeof(DELTA_POINT)`, allowing a malicious RDP peer to allocate an undersized heap buffer and then write beyond it during initialization. This i...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-07-10



CVE-2026-57158

Descripción: FreeRDP is a free implementation of the Remote Desktop Protocol. From 3.21.0 before 3.28.0, FreeRDP clients using the GFX pipeline contain an incomplete fix for CVE-2026-23530 in `planar_decompress_plane_rle_only` in `libfreerdp/codec/planar.c`, allowing a malicious RDP server to send a truncated `RDPGFX_CMDID_WIRETOSURFACE_1` planar payload that reads one byte past the input buffer. This issue is fi...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

Tipo: CWE-125

Tecnología: No especificado

Publicado el: 2026-07-10



CVE-2026-57211

Descripción: RabbitMQ is a messaging and streaming broker. Prior to 4.1.11 and 4.2.6 on Windows, the RabbitMQ management plugin static file handler `rabbit_mgmt_wm_static` can pass URL-encoded backslashes to `erl_prim_loader:read_file_info` before path validation when multiple management extension plugins are enabled, causing outbound DNS and SMB requests to attacker-controlled UNC paths. This issue is fixed in...

CVSS: 6.5 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-36

Tecnología: No especificado

Publicado el: 2026-07-10



CVE-2026-57216

Descripción: RabbitMQ is a messaging and streaming broker. Prior to 3.13.15, 4.0.20, 4.1.11, and 4.2.6, AMQP 0-9-1, AMQP 1.0, and Stream Protocol authentication can allow a loopback-restricted user such as guest to connect remotely when traffic is accepted through a trusted PROXY-protocol path and the backend listener is loopback-bound because the loopback check uses the listener-side socket address instead...

CVSS: 6.8 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:N/A:N

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-07-10



CVE-2026-56372

Descripción: ImageMagick before 7.1.2-19 contains a heap buffer overflow vulnerability in the magnify operation that allows attackers to read out of bounds memory. An unrecognized magnify:method value triggers an out of bounds read, potentially exposing sensitive information or causing denial of service.

CVSS: 3.3 (LOW)

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:L

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-07-11



CVE-2026-40468

Descripción: Integer overflow vulnerability has been found in "builtin.c" program file of gawk. This issue may lead to memory exhaustion on the hosting operating system and could be used to overwrite gawk heap metadata and objects with attacker-controlled bytes. It affects gawk in versions 5.4.0 and below.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-190

Tecnología: No especificado

Publicado el: 2026-07-13



CVE-2026-40469

Descripción: Integer overflow vulnerability has been found in "builtin.c" program file of gawk (do_sub() routine). This issue could be used to overwrite gawk heap metadata and objects causing the program to crash. It affects 32-bit builds of gawk in versions 5.4.0 and below.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-190

Tecnología: No especificado

Publicado el: 2026-07-13



CVE-2026-61500

Descripción: Rejetto HFS 3.0.0 through 3.2.0 derives its session-cookie signing key from the non-cryptographic Math.random() generator and discloses outputs of the same generator to unauthenticated clients during login. A remote attacker can collect a small number of login responses, reconstruct the generator's state, recover the signing key, and forge a valid administrator session cookie, leading to full a...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-338

Tecnología: No especificado

Publicado el: 2026-07-13



CVE-2026-58319

Descripción: Certain Apache Doris FE HTTP REST administrative APIs were accessible without proper authentication. An unauthenticated attacker with network access to the FE HTTP service could perform unauthorized administrative operations, potentially affecting cluster integrity and availability and leading to cluster instability or denial of service.

This issue affects Apache Doris versions prior to 3.1.0...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-62390

Descripción: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in Apache Kylin. A backend API refreshing table catalog may cause the injection to the generated SQL.

This issue affects Apache Kylin: from 4 through 5.0.3.

Users are recommended to upgrade to version 5.0.4, which fixes the issue.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-62392

Descripción: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability in Apache Kylin. A backend API may bring job config parameters to OS command line.

This issue affects Apache Kylin: from 4 through 5.0.3.

Users are recommended to upgrade to version 5.0.4, which fixes the issue.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-07-14



Resumen del Reporte

CVEs analizados: 26

Promedio CVSS: 8.21

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

